

Lösenordsskydd Lösenord hashas med BCrypt (workFactor 12) innan lagring i databasen. BCrypt är en adaptiv hashfunktion med inbyggt salt vilket skyddar mot rainbow table-attacker och brute force. Klartext-lösenord lagras aldrig i databasen. Detta adresserar OWASP A02 – kryptografiska fel.

Skydd mot dubbelregistrering Vid registrering kontrolleras om användarnamnet redan finns via AnyAsync. Utöver applikationslogiken finns ett unikt index på Username-kolumnen i databasen som förhindrar dubletter även på databasnivå.

Felhantering vid inloggning Samma felmeddelande — "Ogiltiga inloggningsuppgifter" — returneras oavsett om användarnamnet saknas eller lösenordet är fel. Detta förhindrar user enumeration och adresserar OWASP A07:2021 – Identifiering och autentiserings fel.

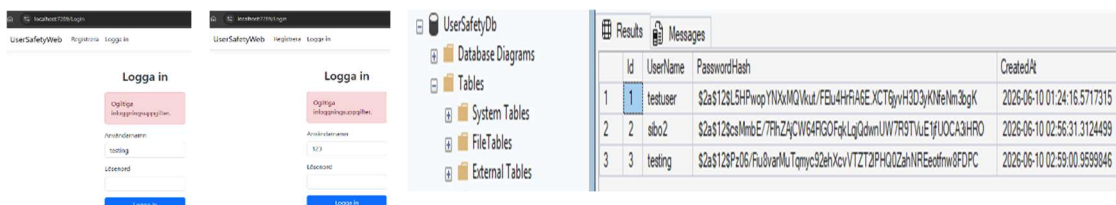
JWT-autentisering Efter lyckad inloggning utfärdas en JWT-token signerad med HMAC-SHA256. Token validerar Issuer, Audience, livstid (30 min) och signaturnyckel. Den hemliga nyckeln lagras i .NET User Secrets och aldrig i versionshanterad kod, vilket adresserar OWASP A02 – kryptografiska fel samt A05 – säkerhets felkonfiguration. Att lagra nycklar utanför källkoden förhindrar att känslig kryptografisk information exponeras i GitHub-repot.

```
5  {
6    "Jwt": {
7      "Issuer": "UserSafetyAPI",
8      "Audience": "UserSafetyWeb"
9    }
10 }
```

SQL-databas Entity Framework Core används för all databaskommunikation. EF Core genererar parameteriserade queries automatiskt vilket förhindrar SQL-injection (OWASP A03 – Injection). Connection stringen använder Windows-autentisering (Trusted_Connection=True) mot LocalDB vilket innebär att inga känsliga databasuppgifter lagras i konfigurationsfiler (OWASP A05 – säkerhets felkonfiguration).

Förebyggda sårbarheter (OWASP Top 10)

- **A02 – Cryptographic Failures:** BCrypt med workFactor 12 och JWT-nyckel i User Secrets
- **A03 – Injection:** EF Core med parameteriserade queries förhindrar SQL-injection
- **A05 – Security Misconfiguration:** Känslig konfiguration hanteras via User Secrets och Windows-autentisering.
- **A07 – Identification and Authentication Failures:** Generiska felmeddelanden och BCrypt-verifiering



The image contains three screenshots. The leftmost shows the 'Logga in' (Login) form with fields for 'Användarnamn' (Username) and 'Lösenord' (Password), and a 'Logga in' button. The middle screenshot shows the 'Logga in' form with a red error message: 'Ogiltiga inloggningsuppgifter.' (Invalid login credentials). The rightmost screenshot shows the 'UserSafetyDb' database structure in SQL Server Enterprise Designer, displaying a table named 'Users' with columns 'Id', 'Username', 'PasswordHash', and 'CreatedAt'.

Id	Username	PasswordHash	CreatedAt
1	testuser	\$2a\$12\$15HPwopY1XvMQ2Vku/FBw4HfAGEXCT8yvH3D3yKNVeNm3ogK	2026-06-10 01:24:16.5717315
2	sbo2	\$2a\$12\$csMmbE7PhZ4yCIV64RGOFGkLqJdwmUW7R9TVUEfUOCA3HRO	2026-06-10 02:56:31.3124499
3	testing	\$2a\$12\$Pz06/Fu0vanMuTgmYc\$2ehXcvVTZT2PHQ0ZahNREoofhw0FDPC	2026-06-10 02:59:00.9599046

Säkerhetsstandard Arbetet följer principerna i ISO 27002 gällande åtkomstkontroll och lösenordshantering.